

Entregas Esperadas - Challenge Sprint 3 - Cybersecurity

Um Documento sobre o método avaliativo e o que esperar da terceira Sprint de Cybersecurity

Visão Geral

A entrega será dividida em 4 etapas:

1. Pipeline DevSecOps & Análise de Código
2. Segurança de Código e Infraestrutura
3. Logs, Alertas e Resposta a Incidentes
4. Pesquisa de Vulnerabilidades

Etapas

Etapa 1: Pipeline DevSecOps & Análise de Código

Objetivo: Demonstrar a aplicação prática de ferramentas de segurança no pipeline e no código.

O que deve ser entregue:

- Implementação de **SAST** utilizando o **Semgrep** - Evidenciando varreduras e regras aplicadas no código.
- Implementação de **Secret Scanning** utilizando o **Trufflehog** - Evidenciando a busca por credenciais vazadas ou chaves expostas.
- **Orientações e Pesquisa Orientada:** Breve contextualização e busca sobre *SCA (Software Composition Analysis)* e *Container Security*, mesmo que não aplicadas diretamente em código, explicando onde elas entrariam no ecossistema.

Entrega esperada: Documento + diagrama do CI/CD com os pontos de execução do Semgrep e Trufflehog + prints/resultados das varreduras.

Etapa 2: Segurança em Código e Infraestrutura

Objetivo: Evidenciar práticas de segurança aplicadas diretamente no código e na infraestrutura.

O que deve ser entregue:

- Evidências de correções ou melhorias reais no código:
 - Criptografia local.
 - Hardening de API (rate limit, validação de entrada, JWT seguro).
 - Controle de acesso por perfil (Brigadista, Gestor, Administrador) | RBAC.

Entrega esperada: Trechos de código, prints, commits, explicações técnicas.

Etapa 3: Logs, Alertas e Resposta a Incidentes

Objetivo: Mostrar como o sistema registra eventos críticos e como a equipe reage a um incidente de segurança.

O que deve ser entregue:

- Plano de monitoramento focado em:
- Logs estruturados (login, falhas de autenticação, alterações críticas).
- Métricas e alertas relevantes (API, mobile, IoT, ML).
- Plano e fluxo de resposta a incidentes (**SANS PICERL**):
 - **Preparação → Identificação → Contenção → Erradicação → Recuperação**

**Nota: Não será necessário documentar Lições Aprendidas!*

Entrega esperada: Exemplos de logs estruturados, regras/gatilhos de alertas e o fluxo documentado de resposta a incidentes aplicados ao projeto.

Etapa 4: Pesquisa de Vulnerabilidades (OWASP Top 10 e API)

Objetivo: Mapear e pesquisar vulnerabilidades críticas comuns em aplicações web e APIs para blindar a arquitetura da solução.

O que deve ser entregue:

- Pesquisa direcionada e mapeamento prático baseada em:
- **OWASP Top 10** (identificando quais riscos se aplicam ou poderiam se aplicar ao projeto e como evitá-los).
- **OWASP API Top 10** (focado nas vulnerabilidades específicas das APIs desenvolvidas). - Análise de riscos e recomendações de mitigação para o cenário escolhido.
- **OWASP Mobile Top 10** (focado nos riscos e vulnerabilidades do aplicativo mobile da solução).
- **OWASP ASVS (Application Security Verification Standard)** (utilizando o padrão para definir níveis/requisitos de verificação de segurança na arquitetura).
- Análise de riscos e recomendações de mitigação para o cenário.

Entrega esperada: Documento consolidado com a pesquisa de vulnerabilidades, matriz de mapeamento para o projeto e plano de mitigação.